Individual Assignment

CT108-3-M-ISD

Information Security Design

NAME	**: Soni DIEDHIOU**
TP NUMBER	**: TP134616**
INTAKE CODE	**: APUMF2512CYS**
MODULE TITLE	**: Information Security Design**
MODULE LECTURER	**: Dr. Jalil Md Desa**
PROJECT TITLE	**: Information Security Design of Free / Iliad Group**
HAND OUT DATE	**: 29/01/2026**
HAND IN DATE	**: 19/04/2026**

Abstract

The current report deals with the information security design of Free, which is one of the leading French telecom operators and a wholly owned subsidiary of Iliad Group. Although Free aims at a significant scale, with over 23 million subscriber contracts under management in France, **a** majority share in the sovereign cybersecurity company ITrust, and twelve certified datacenters as indicated by its subsidiary Free Pro that is ISO 27001-certified, Free has structural weaknesses in its security architecture that have been confirmed by a formal regulatory investigation. The present report is based on official primary documents such as CNIL deliberations SAN-2026-001 and SAN-2026-002, ANSSI threat intelligence reports CERTFR-2023-CTI-010 and CERTFR-2025-CTI-003, as well as the NIS 2 Directive and the GDPR, which identify the security gaps**.** All gaps are cross-mapped to the Zero Trust Architecture (ZTA) framework as per NIST SP 800-207, and a particular, evidence-based improvement is suggested and supported by referencing relevant standards, industry best practices and organisational specifics. The report also covers recovery strategies, business continuity planning, and ongoing compliance management requirements that develop out of the NIS 2 Directive and the GDPR. The main analysis is that Free did not experience the security-related failures due to resource limitations or technological inabilities; it lacked governance: the group has the means, the skills, and the facilities to protect its consumer data, but it did not apply them at the group level. This organizational contradiction — a subsidiary with an internal cybersecurity unit whose services were not directed internally to secure the parent company subscribers' data — is what makes up the centerpiece of this analysis.

Table of Contents

Abstract *2*

Table of Contents *3*

1. Organization Overview *4*

1.1 Corporate Identity and Market Position **4**

1.2 Group Structure and Subsidiaries **5**

1.3 The Central Paradox: Capability Without Coverage **6**

2. Current Information Security Design *9*

2.1 Technical Architecture and Network Design **9**

2.2 Declared Compliance Posture **10**

2.3 Governance Arrangements **11**

3. Security Weaknesses and Gap Analysis *13*

3.1 Weakness 1 — Insufficient VPN Authentication (W1) **15**

3.2 Weakness 2 — Uncontrolled Privileged Access to MOBO (W2) **16**

3.3 Weakness 3 — Absence of SOC and Behavioural Detection (W3) **16**

3.4 Weakness 4 — Excessive Personal Data Retention (W4) **17**

3.5 Weakness 5 — Incomplete Breach Notification (W5) **17**

3.6 Weakness 6 — Insufficient Third-Party Data Transfer Security (W6) **18**

3.7 Weakness 7 — Absence of ISO 27001 for Consumer Entities (W7) **18**

3.8 Weakness 8 — Deficit of Group-Level Cyber Governance (W8) **19**

4. Zero Trust Architecture Framework *21*

4.1 The Seven Tenets **21**

4.2 The Three Logical Components **22**

5. Proposed Improvements and Solutions *24*

5.1 Solution for W1 — Zero Trust Network Access and FIDO2 Phishing-Resistant MFA **25**

5.2 Solution for W2 — Privileged Access Management with Just-In-Time Provisioning **26**

5.3 Solution for W3 — 24/7 SOC with Reveelium SIEM, UEBA, and SOAR **27**

5.4 Solution for W4 — Data Security Posture Management and Automated Retention Enforcement **28**

5.5 Solution for W5 — Formalised Incident Response Plan with SOAR-Automated Notification **29**

5.6 Solution for W6 — Third-Party Risk Management with NIS2-Aligned Supply Chain Security **30**

5.7 Solution for W7 — ISO 27001 Certification Extended to Free and Free Mobile.....31

5.8 Solution for W8 — Group CISO, COMEX Cyber Committee, and Governance Programme 31

6. Recovery Strategies and Compliance Management.....34

6.1 Business Continuity and Disaster Recovery Planning.....34

6.2 Continuous Compliance Management.....35

7. Conclusion.....37

References.....39

1. Organization Overview

Figure 1. Free's headquarters, Paris, France. (Google Street View, 2023).

1.1 Corporate Identity and Market Position

Free is a French telecommunications company that was established in 1999 by entrepreneur Xavier Niel and is integrated as part of the Iliad Group holding structure. Free is one of the largest telecommunications companies in the country — it started as a disrupter, a low cost internet service provider, and has expanded to become one of the largest. Its most significant market entry was a January 2012 launch of a €2/month SIM-only mobile product that shook up competitive pricing permanently in the French mobile market by compelling the three established operators to redefine their pricing schemes within a few weeks.

Iliad S.A. achieved revenues of €10.024 billion as of financial year 2024, becoming the first time the group reached the mark of 10 billion, growing at a rate of 8.5 per cent annually. The EBITDAaL of the group is €3.85 billion and the margin is 38.4% and net profit is €367 million (Iliad S.A., 2025). Iliad is the fifth-largest telecommunications operator in Europe based on the number of subscribers with a total of 50.2 million in France, Italy via iliad Italia and Poland via Play. France is the largest market with a contribution of €6.534 billion, representing 65% of group revenue and a subscriber base of about 23 million contributing contracts in mobile and fixed broadband: 15.51 million mobile and 7.56 million fixed broadband.

This market position puts the group in direct competition with Orange, SFR and Bouygues Telecom. Market share is analytically important beyond scale: the four large operators in France are all similarly scaled, subject to the same regulatory requirements and share common internal subscriber management structures. According to the 2023 threat assessment of the telecommunications sector by ANSSI, the shared architectural patterns provide shared vulnerabilities, and the structural prioritisation of availability over data confidentiality and system integrity is a characteristic of a sector-wide nature and not a weakness of individual firms (ANSSI / CERT-FR, 2023). This observation puts the security posture of Free in perspective, as not just a failure in isolation but as a case of a reported systemic design pattern within the French telecom industry.

In France, Free is regulated by the ARCEP, the telecommunications regulator, and has the status Opérateur de Communications Électroniques (OCE). Its regulatory classification with the most significant impact on information security is that it has been designated as an Essential Entity under Annex I of the NIS 2 Directive, the comprehensive framework on network and information systems security that the European Union set up, which came into effect on 18 October 2024 (European Parliament, 2022). Being a GDPR data controller that deals with the personal data of tens of millions of people, and as convergent subscribers can bundle both fixed and mobile services, including the bank account (IBAN) data of the latter, Free is subjected to a combination of many overlapping regulations with maximum penalties of tens of millions of euros.

1.2 Group Structure and Subsidiaries

The Iliad Group is organized in a chain of holding vehicles. The parent company, Iliad S.A., which is publicly listed, is governed by Iliad Holding S.A.S. and the middle-level investment fund Freya Investissement. At the operational tier, the French telecommunications business of the group is split into Free SAS and Free Mobile SAS: the former offers fixed-line and broadband services to customers under the Freebox product brand and the latter offers mobile services. The two are classified under the combined perimeter of the Iliad Group — a legal structure that has a material regulatory impact: according to case law under the Court of Justice of the European Union on economic unity, the sanctioning authorities can impose fines based on consolidated group turnover, not just on the subsidiary's individual turnover (CNIL, 2026; Haas Avocats, 2026).

In addition to its consumer-facing brands, the Iliad ecosystem has a number of technically important subsidiaries, which are the focus of this report. The B2B cloud and managed services division of the group is Free Pro, which has twelve datacenters certified under ISO 27001 and the HDS standard. Its infrastructure includes the technical landmark DC4 site in Paris, an anti-atomic bunker 26 metres beneath ground level, managed by OpCore, which is the physical datacenter management entity of the group. Scaleway offers sovereign French public cloud services, on record as an alternative to US hyperscalers and intended to prevent data access exposure under the Cloud Act and PATRIOT Act. Iliad invested 3 billion dollars in OpCore, Scaleway and AI research lab Kyutai in 2025, as part of the group's strategic shift to high-compute sovereign infrastructure (Iliad S.A., 2025).

Of particular relevance to this discussion is ITrust, the subsidiary responsible for the cybersecurity of the group, which became a part of Free Pro in April 2023. At the time of the acquisition, Iliad CEO Thomas Reynaud stated that the group was addressing one of the key issues in the industry, namely cybersecurity, with the specific aim of democratising cybersecurity skills for enterprises and government bodies (Iliad Group, 2023). The flagship of ITrust is the fully proprietary ANSSI-qualified SIEM, XDR, UEBA, and SOAR platform called Reveelium, operated by a 24/7 Security Operations Centre. During the twelve months before June 2024, the SOC at ITrust analyzed more than a million alerts and detected 400,000 threats on behalf of its external customers (ITrust, 2025). Its clients include six CAC 40 companies, various French government ministries, and regulated operators that are Opérateurs d'Importance Vitale (OIV) — subject to national security requirements stronger than those of NIS 2 Essential Entities. Iliad Group is also listed as a client of the ITrust SOC. Reveelium recorded over 50% annual growth in software activity and added NIS 2 compliance features to incident reporting in July 2025, V12.3 (ITrust, 2025).

1.3 The Central Paradox: Capability Without Coverage

The Iliad Group has a structural paradox in its organisational profile that is the analytical focus of this report. The group operates a 24/7 AI-based cybersecurity platform (Reveelium), 12 ISO 27001-certified datacenters, a sovereign cloud platform designed to support regulatory-grade data security, and a cybersecurity subsidiary whose customers include government ministries in France and the most sensitive regulated operators in the country. However, the consumer subsidiaries

managing 23 million subscriber contracts — Free SAS and Free Mobile SAS — are not subject to the same information security controls applied across the rest of the group's infrastructure.

This imbalance is not accidental. Since April 2023, Reveelium is a commercial offering by ITrust to external B2B clients whose data assets and regulatory requirements are in the vast majority of cases less sensitive than those of a telecommunications operator controlling 23 million subscriber contracts and IBAN records. The particular functions Reveelium offers — behavioural anomaly detection, mass data exfiltration alerts, privileged session monitoring, and SOAR-assisted incident response — are precisely the functions whose absence on the consumer side of the group defines the structural security design gap. The paradox is one of governance priority rather than technical incapacity: the group has prioritized cybersecurity as a B2B commercial product instead of an operational necessity for its biggest and most regulated business unit.

To address this paradox analytically, it is important to understand the security design in place on the consumer side of the group — its architecture, its compliance posture, and its governance arrangements. This is the subject of the examination in Section 2. Table 1 below provides the consolidated organisational profile of Free and the Iliad Group.

Dimension	Data
Legal entities	Free SAS (consumer fixed broadband) and Free Mobile SAS (consumer mobile), both wholly owned subsidiaries of Iliad S.A.
Sector	Telecommunications — fixed broadband, mobile (4G/5G), B2B cloud, datacenter infrastructure, sovereign cybersecurity
Subscribers (France)	~15.51 million mobile + 7.56 million fixed broadband = ~23 million French subscriber contracts (Iliad S.A., 2025)
Group revenue FY2024	€10.024 billion (+8.5% YoY); France: €6.534 billion (65%); EBITDAaL: €3.85 billion (+11.8%); net profit: €367 million (Iliad S.A., 2025)
European rank	5th largest telecommunications operator in Europe by subscriber count, 50.2M total (France + Italy + Poland) (Iliad S.A., 2025)
Key subsidiaries	Free, Free Mobile, Free Pro (B2B), Scaleway (public cloud), OpCore (datacenters), ITrust (cybersecurity, acquired April 2023), iliad Italia, Play (Poland)
Active certifications	ISO 27001 and HDS: 12 Free Pro / OpCore datacenters. ISO 27001: absent for Free SAS and Free Mobile SAS (Free Pro, 2024)
Regulatory classification	Essential Entity under NIS 2 Directive Annex I (telecommunications); GDPR data controller; regulated operator (OCE) under ARCEP (France)

Staff (group)	18,200+ employees globally (Iliad S.A., 2025)

Table 1. Organisational profile of Free / Iliad Group. Compiled from Iliad S.A. (2025), Free Pro (2024), CNIL (2026), and ANSSI (2023).

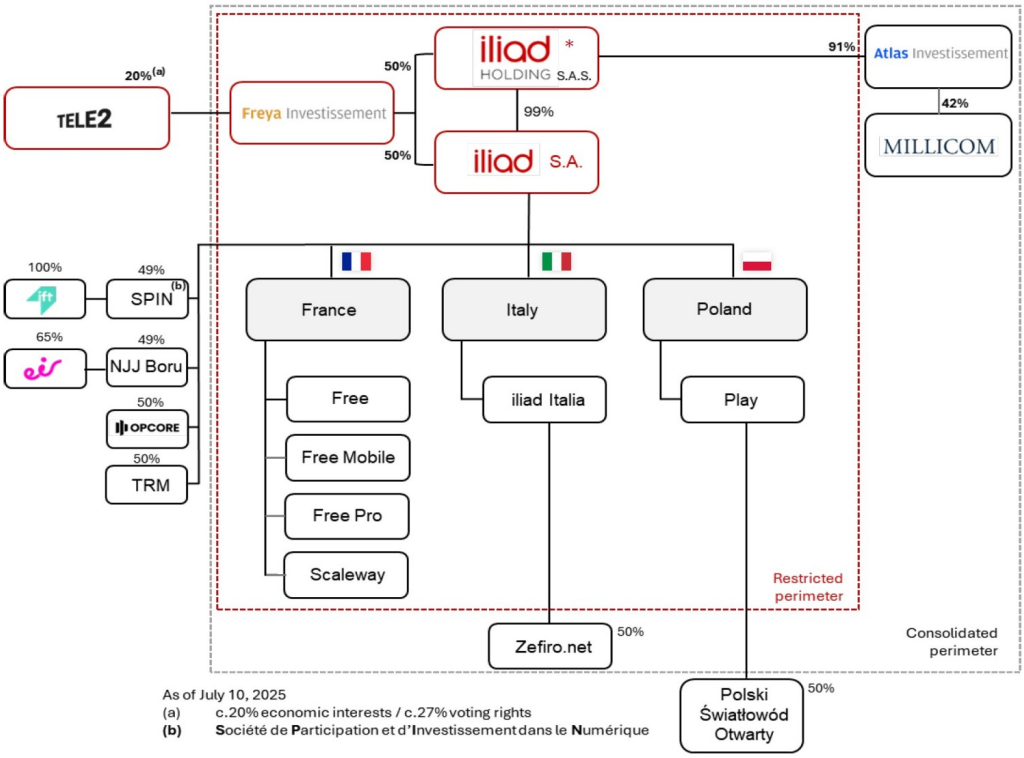

Figure 2. Iliad Group organisational structure as of July 2025. Visible at iliad.fr

2. Current Information Security Design

To determine where the information security design of Free is wanting, we must first determine what that design is — not what it claims to be, but how it is structured. This section outlines the technical architecture used in the consumer operations, the compliance posture that Free claims against the relevant regulatory requirements, and the governance arrangements. The difference between the security posture that Free presents and what it actually implements is in itself the first sign of a structural gap — a gap that has been confirmed by the findings of formal regulation.

2.1 Technical Architecture and Network Design

The subscriber management activity of Free Mobile is based on an internal application named MOBO — a centralised tool by which operational staff could access and edit subscriber records, such as personal information, addresses, dates of birth, phone numbers, as well as bank account (IBAN) information for convergent subscribers taking both mobile and fixed-line services. A corporate VPN gateway is used to provide remote access to internal systems, including MOBO. Such a system — remote VPN access to a subscriber management database — is universal in the telecommunications industry and not insecure per se. What matters to security is the structure of the authentication controls, the monitoring instrumentation surrounding such systems, and the data management techniques applied to the records held within them.

The VPN is accessible without strong multi-factor authentication. Remote endpoints do not require any machine certificate — a control that ANSSI formally recommended since 2018 in its guidance on multi-factor authentication, ANSSI-PG-078, and one that the CNIL has recognised as the relevant state-of-the-art standard under Article 32 GDPR (ANSSI, 2021). A machine certificate verifies the connecting device regardless of user credentials, ensuring that only managed, corporate-enrolled endpoints are permitted entry to internal systems. Without it, valid user credentials alone are sufficient to authenticate to the VPN, which creates a single credential-based point of failure — according to the Verizon 2024 DBIR, compromised credentials remain the number one initial access vector in confirmed data breaches worldwide (Verizon, 2024).

Free Mobile does not use a Security Operations Centre (SOC) or centralised behavioural anomaly detection for its consumer IS infrastructure. The 2023 threat assessment conducted by ANSSI

notes that telecommunications organisations tend to prioritise service availability over data confidentiality and system integrity, and that hardening security is difficult given the large scale of the networks and the accumulated technical debt of major operators (ANSSI / CERT-FR, 2023). This structural prioritisation is evident in the architecture of Free: the VPN and MOBO are designed to operate at scale, and the absence of centralised monitoring reflects an untested design choice rather than a gap that had been studied and formally accepted.

In the MOBO application, passwords have been stored using inadequately robust hashing algorithms. This was determined by the CNIL to be a breach of Article 32 GDPR on the grounds that it does not use a memory-hard hashing function such as Argon2, BCrypt, or scrypt — the standard recommended in CNIL guidance on password storage dating back to 2017 and reaffirmed in 2022 (Altij Avocats, 2026). Memory-hard hashing has been the established standard for over a decade, codified in official guidance that Free, as a GDPR data controller, is responsible for implementing and maintaining.

2.2 Declared Compliance Posture

The formal compliance posture of the group presents a structurally split image. At the certified infrastructure tier, Free Pro and OpCore hold ISO 27001 certification across all twelve datacenters, and HDS certification for health data hosting — a stringent standard that mandates external audit and an operational ISMS including annual surveillance, regular risk assessment, and a Plan-Do-Check-Act cycle of continuous improvement (Free Pro, 2024). This certification shows that Iliad Group management understands what an effective information security management programme looks like and has invested in building one — in its B2B business.

Free SAS and Free Mobile SAS — the entities responsible for 23 million consumer subscriber contracts — hold no equivalent ISO 27001 certification. Certification, as defined by ISO (2022), implies that an organisation has implemented a system that manages the security risks associated with the data it owns or processes, in accordance with the best practices and principles of the standard. In the absence of such a framework, consumer-side security governance relies on informal mechanisms, personal experience, and checklists rather than a formalised, audited management risk cycle. The practical implication is significant: the consumer subsidiaries do not

undergo the routine risk assessment, third-party audit, and management accountability that ISO 27001 mandates — the absence of which allowed the gaps identified in Section 3 to go undetected.

On GDPR compliance, Free and Free Mobile have designated a Data Protection Officer and maintain basic accountability records, including privacy notices, consent management, and data access request procedures. However, the technical application of Article 32 requirements — suitable technical and organisational measures proportionate to the risk, in light of the state of the art — has been found wanting in several areas. The CNIL and ANSSI recommendations have been recognised by the courts as the applicable state-of-the-art standard under Article 32 (Altij Avocats, 2026). The failure to implement them is therefore not only a security vulnerability but a confirmed legal liability.

The external threat context against which this compliance posture must be evaluated is provided by the ENISA Threat Landscape 2024: targeting internet-facing services — VPNs, firewalls, and management interfaces — through known vulnerabilities was the most prevalent attack vector across European digital infrastructure in 2023–2024, and France was the fourth most affected EU Member State, accounting for 9.5% of EU incidents. Article 21(2) of NIS 2 sets out a minimum baseline for Essential Entities, including multi-factor authentication (Art. 21(2)(j)), incident management (Art. 21(2)(b)), supply chain security (Art. 21(2)(d)), and access control policies (Art. 21(2)(i)) (European Parliament, 2022). The existing architecture of Free presents verifiable gaps against at least four of these categories — a degree of regulatory exposure that is inconsistent with its classification as an Essential Entity.

2.3 Governance Arrangements

At group level, there is no publicly visible Chief Information Security Officer (CISO), nor is there evidence that a board-level or COMEX-level cyber risk committee oversees the consumer IS security of Free (NIS2 Governance analysis, 2024). The governance arrangement is functional: IT departments manage system access, the DPO handles GDPR compliance documentation, and legal teams manage regulatory relationships. Cybersecurity strategy — distinct from IT operations — does not have a dedicated executive owner, assigned budget, or board-level accountability.

According to the CESIN 11th Barometer, which surveyed 401 French Chief Information Security Officers in 2025–2026, 90% of French firms monitor cyber risk at COMEX or CODIR level, and 94% deploy MFA while 95% deploy EDR as near-universal baseline controls (CESIN, 2026). These figures establish a clear industry norm: board-level cyber governance, strong authentication, and endpoint detection are standard practice among French enterprises of comparable size. The absence of these arrangements at Free represents a measurable governance deficit relative to its peer group, not a deliberate strategic choice.

The SOC capabilities of ITrust are provided to external B2B clients, and Iliad Group itself is listed as an ITrust SOC client for enterprise-level services. There is no indication, however, that the same level of continuous monitoring is applied to the consumer IS infrastructure of Free Mobile, the MOBO system, the VPN gateway, or the subscriber database. This disparity between the group's stated cybersecurity capability and its actual application on the consumer side is the governance failure that allowed the structural weaknesses identified in Section 3 to persist. The fact that these weaknesses were formally recognised and sanctioned by the CNIL through a regulatory procedure confirms that the governance gap had tangible legal consequences.

3. Security Weaknesses and Gap Analysis

The Free Mobile incident in October 2024 shows a chain of operational anomalies that, when compared to the official regulatory results, the history of the group, and the threat environment of the sector, suggests that there were some structural vulnerabilities in the information security design. On 28 September 2024, the attacker first accessed the VPN, and on 6 October, started stealing data with MOBO, which went unnoticed until they decided to publicize the intrusion on 21 October, a total of 25 days during which 24,633,469 subscriber contracts and 5,110,000 IBAN records were stolen. The discovery mechanism — a message posted by the attacker, not a security alert — is perhaps the most diagnostic single fact in the case, since it allows concluding that there was no effective detection of the anomaly throughout the period of the attack.

In deliberations SAN-2026-001 and SAN-2026-002, the CNIL was clear on what its findings were. The regulator verified that the companies had not taken some of the simplest security measures, which would have complicated the attack, at the time of the data breach (CNIL, 2026). The CNIL legal framework does not penalize the breach per se, but the lack of measures which facilitated the breach to occur — evaluated against the state of the art at the time (Altij Avocats, 2026). This frames every CNIL finding as a post-incident confirmation of a structural design failure that existed prior to the breach. The CNIL also described its findings as the exposure of a series of security failures enabling the attacker to take a step-by-step approach through the IS (CNIL, cited in Village Justice, 2026).

The group's regulatory history supports the structural argument. In December 2021, the CNIL sanctioned Free Mobile for transmitting passwords in cleartext via email — a credential security failure of the lowest order (CNIL, 2021). In November 2022, Free SAS was sanctioned again for storing passwords in plaintext in its subscriber database, reassigning 4,100 Freebox routers to new subscribers without clearing the data of prior subscribers, and failing to document a data breach in the incident register (CNIL, 2022). Legal analysis confirms that the SAN-2026-001 deliberation directly references SAN-2021-020 as precedent on Article 32 violations — the 2026 findings are directly tied to the 2021 pattern (Village Justice, 2026). Three sanctions over five years do not record a failure but a pattern — a structurally ingrained pattern of poor security design that was uncovered, confirmed, and left unremedied.

This analytical stance is reinforced by the sector comparison. The Verizon 2024 Data Breach Investigations Report, which examined 30,458 security incidents and 10,626 confirmed breaches across 94 countries, found that stolen credentials were the most common initial access method, involved in 38% of all confirmed breaches — more than twice the share attributable to phishing (Verizon, 2024). Personal data was the most prevalent type of data compromised, involved in almost 60% of breaches. Third-party involvement rose 68% year-on-year and featured in 15% of breaches. The Free incident fits the Verizon DBIR pattern: credential-based initial access, mass personal data exfiltration, privileged tool exploitation. Table 2 below presents the eight structural weaknesses identified, with supporting evidence and Zero Trust mapping.

	Weakness	Primary Evidence	ZTA Tenet Violated	Gap Identified
W1	Insufficient VPN authentication	CNIL SAN-2026-001; ANSSI-PG-078 (2018/2021)	Tenet 6 — Dynamic, strictly enforced authentication before every session	No machine certificate; no FIDO2/strong MFA; single-factor VPN grants broad internal network access
W2	Uncontrolled privileged access to MOBO	CNIL SAN-2026-001; Haas Avocats (2026); Palo Alto Networks (2024)	Tenets 3 & 4 — Per-session least-privilege; dynamic access policy	No PAM; no Zero Standing Privilege; no JIT provisioning; persistent mass data access post-authentication
W3	Absence of SOC and behavioural anomaly detection	CNIL SAN-2026-001; Freenews (2026); ANSSI CERTFR-2025-CTI-003	Tenet 7 — Continuous collection and analysis of asset and communication data	No SOC pre-breach; anomaly detection ineffective; 25 days of exfiltration undetected
W4	Excessive personal data retention beyond legal periods	CNIL SAN-2026-001; Village Justice (2026); Altij Avocats (2026)	Tenet 1 — All data sources and computing services are managed resources	15M+ terminated contracts retained >5 years; 2.8M+ retained >10 years; purge mechanism non-operational
W5	Incomplete and non-compliant breach notification	CNIL SAN-2026-001; Altij Avocats (2026); Haas Avocats (2026)	Tenet 7 — Continuous monitoring and post-incident response	Notification email lacked concrete remediation and consequence description; Art. 34(2) GDPR non-compliant
W6	Insufficient security of third-party data transfers	CNIL SAN-2026-001; Freenews (2026); NISTIR 8276	Tenet 2 — All communications secured regardless of network location	No documented TPRM; no contractual security requirements for data processors; no DLP at transfer boundaries
W7	No ISO 27001 for Free / Free Mobile	Free Pro (2024); ISO (2022); CNIL SAN-2026-001	Tenet 5 — Monitor and measure integrity and security posture of all assets	B2B side ISO-certified; consumer side with 23M subscribers not subject to any ISMS audit framework
W8	Deficit of group-level cyber	NIS2 Art. 20; Freenews (2026);	Tenet 4 — Enterprise-wide dynamic security	No Group CISO; no COMEX cyber committee; SOC deployed

	governance	CESIN Baromètre (2026)	policy	post-breach only; no board-level accountability

Table 2. Free / Iliad Group ISD weaknesses mapped against Zero Trust Architecture principles.

3.1 Weakness 1 — Insufficient VPN Authentication (W1)

Concerning authentication, the CNIL found the VPN login process to be not secure enough (CNIL, 2026). The issue was the missing machine certificate on remote devices — a control mentioned in ANSSI guidance ANSSI-PG-078 as early as 2018, and declared by the CNIL in its opinion as the state-of-the-art standard (ANSSI, 2021). A machine certificate verifies that the device is managed by the company, not just the credentials of the user. That way, despite having a username and a password, one could not connect using a device that was not controlled by the company. At Free this check was absent. The VPN only required a username and password, which made it a single point of failure that could be exploited by stealing or buying credentials on the black market.

The ENISA Threat Landscape 2024 puts this in context: most attacks on infrastructure that year targeted internet-facing services like VPNs (ENISA, 2024). Cisco Duo found that 56% of organisations had been victims of cyberattacks based on VPN vulnerabilities, and 58% of ransomware attacks came from a compromised VPN or security appliance (Cisco Duo, 2024). The 2025 ANSSI panorama put MFA on all exposed surfaces — VPN, email, administration consoles, and cloud — as its top preventive recommendation (ANSSI / CERT-FR, 2025). Free had violated that requirement at least six years before the incident.

On Zero Trust: NIST SP 800-207 Tenet 6 requires all authentication and authorisation procedures to be enforced before access is granted (Rose et al., 2020). Free's VPN checked credentials once, not continuously, and had no device-level verification. The authentication decision was incomplete by design.

3.2 Weakness 2 — Uncontrolled Privileged Access to MOBO (W2)

VPN access gave access to MOBO. MOBO gave querying access to mass subscriber records. No PAM controls were in place, so access was unrestricted: no Zero Standing Privilege, no Just-in-Time (JIT) provisioning, no session recording. Palo Alto Networks (2024) notes that removing

standing privileges and enforcing just-in-time access is the first step of ZTA, and it directly limits how far an attacker can move after a credential compromise. None of that was in place at Free. A credential theft turned into a 25-day mass exfiltration because the attacker's MOBO sessions looked identical to those of a legitimate operator.

The impact goes further than the breach itself. Unit 42 data shows compromised credentials as the initial access vector in a disproportionate number of cases, and missing JIT provisioning is what consistently turns that initial access into something lasting (Palo Alto Networks, 2024). No least-privilege controls over MOBO is a direct violation of Tenets 3 and 4 of ZTA, which require per-session access grants and dynamic policy-based access decisions respectively.

3.3 Weakness 3 — Absence of SOC and Behavioural Detection (W3)

Deliberation SAN-2026-001 established that Free Mobile had retained over 15 million contracts of terminated subscribers beyond the limit set by Article 5(1)(e) GDPR, and that more than 2.8 million of those records had been kept for over a decade (Village Justice, 2026; Altij Avocats, 2026). The GDPR storage limitation principle states that personal data must not be stored in identifiable form beyond the time necessary for the purpose of processing. The CNIL rejected Free Mobile's justification that the purge mechanism had not been implemented due to technical constraints and the risk of service disruption. Tenet 1 of ZTA states that all data sources must be managed as controlled resources with defined access and lifecycle policies. The 15+ million retained terminated contracts were unmanaged data with no lifecycle policy — and they directly increased the scale of harm when the breach occurred.

3.4 Weakness 4 — Excessive Personal Data Retention (W4)

CNIL decision SAN-2026-001 held that Free Mobile had stored over 15 million terminated subscriber contracts past the time limit in Article 5(1)(e) GDPR, and that over 2.8 million of those records were over 10 years old, which was a breach of the storage limitation principle. The CNIL did not accept the arguments of Free Mobile that the purge mechanism was not working because of technical limitations and that the threat of service interruption was unacceptable. According to Tenet 1 of the ZTA framework, all data sources and computing resources should be managed resources that have specified access and lifecycle policies. The 15+ million retained terminated

contracts are an uncontrolled data asset that, when breached, greatly increased the harm surface beyond the active operational subscriber base.

3.5 Weakness 5 — Incomplete Breach Notification (W5)

Free sent a notification email to the affected subscribers that the CNIL had determined to be insufficient: Free had simply said that it had done everything possible, without indicating what had been done or what the likely effect of the breach would be on affected individuals (Haas Avocats, 2026). Article 34(2) GDPR stipulates that breach notifications must contain the nature of the breach, contact details of the DPO, likely consequences, and the measures taken or proposed. The notification by Free did not satisfy all four content requirements. The structural cause of poor breach notification quality, as identified by NIST SP 800-61 Rev. 3, is the absence of a formalised Incident Response Plan with pre-approved, legally vetted notification templates — a Preparation phase failure (NIST, 2025).

3.6 Weakness 6 — Insufficient Third-Party Data Transfer Security (W6)

Among its findings, the CNIL identified a lack of security controls over data transfers to third parties as a violation of Article 32 GDPR (CNIL, 2026). Post-incident analysis by Freenews showed that much of the failures originated within the operator ecosystem: call centres, IT service providers, and commercial partners (Freenews, 2026). This is structurally described in NISTIR 8276: threat actors actively target the suppliers of more cyber-mature organisations to exploit the weakest link, and organisations can no longer afford to secure only their own infrastructure (NIST, 2021). According to the CESIN 11th Barometer, 35% of attacks on French enterprises follow third-party or supply chain vectors, rising to 43% among large businesses (CESIN, 2026). Free had no documented TPRM framework, no contractual data processor security provisions, and no right-to-audit clauses — a gap that NIS 2 Article 21(2)(d) specifically identifies as a mandatory requirement for Essential Entities.

3.7 Weakness 7 — Absence of ISO 27001 for Consumer Entities (W7)

Free Pro and OpCore are certified to ISO 27001 in their twelve datacenters, but Free SAS and Free Mobile SAS, which run 23 million consumer contracts, are not (Free Pro, 2024). The eight weaknesses in this analysis are related to the 93 controls of ISO 27001:2022 that are categorized

into the following themes: access control (W1, W2), incident management (W3, W5), information classification (W4), supplier relationships (W6), and leadership and governance (W7, W8). The systematic risk assessment, third-party audit, and management accountability mechanisms that would identify and demand redress of these gaps are not applied to the consumer subsidiaries without certification. Specifically, NIS 2 guidance suggests that ISO 27001 certification is a tool that Essential Entities should use to show that they comply with Article 21 the fact that Free does not have a certified ISMS is a security design failure and a regulatory safe harbour that has been overlooked (ISO, 2022).

3.8 Weakness 8 — Deficit of Group-Level Cyber Governance (W8)

The lack of a Group CISO, the lack of a COMEX-level cyber committee, and the use of simple security measures only after the breach all point to one structural fact: prior to October 2024, cybersecurity was not a component of the corporate governance structure of Free/Iliad. NIS 2, article 20, governance is a legal requirement: management bodies of critical organizations are required to formally endorse cybersecurity risk management practices, monitor their execution, and receive regular cybersecurity training (European Parliament, 2022). Non-compliant executives have their personal liability clearly defined. The CESIN 11th Barometer shows that 90 percent of French firms track cyber risk at COMEX or CODIR level (CESIN, 2026) - the governance gap of Free was therefore quantifiable. The ITrust acquisition in April 2023 gave the group the ability to deliver world-class cybersecurity; the governance failure was that this ability was never turned inwards as a strategic need of the consumer subsidiaries.

Period	Incident / Event	Regulatory Outcome / Source
2014	CVE-2014-9382 — Remote code execution vulnerability in Freebox VPN publicly disclosed.	National Vulnerability Database (CVE record)
Dec 2021	CNIL sanctions Free Mobile €300,000 — passwords transmitted in cleartext by email; users not required to change them (Art. 32 GDPR).	CNIL SAN-2021-021, 28 December 2021
Nov 2022	CNIL sanctions Free €300,000 — passwords stored in plaintext; 4,100 Freeboxes reassigned without data	CNIL SAN-2022-021, 30 November 2022

	erasure; breach not in incident register.	
Apr 2023	Iliad acquires majority stake in ITrust. Reveelium SIEM/UEBA/SOAR available to Iliad Group. Consumer IS (Free/Free Mobile) not equivalently protected.	Iliad Group press release (GlobeNewswire, 4 April 2023)
Dec 2023	ANSSI CERTFR-2023-CTI-010 classifies telecoms as 'super-critical'; operators prioritise availability over data confidentiality.	ANSSI / CERT-FR, CERTFR-2023-CTI-010
Aug–Sep 2024	Bouygues Telecom breach (~6.4M customers). SFR breach via SIBO360 internal management tool (~3.6M clients). Sector-wide exploitation of subscriber management tools.	Usine Digitale / IT-Connect (2024)
28 Sep–22 Oct 2024	28 Sep: attacker authenticates via Free Mobile VPN. 6 Oct: exfiltration begins via MOBO. 17 Oct: dataset posted on BreachForums. 21 Oct: attacker notifies Free. 22 Oct: attacker expelled. 26 Oct: public confirmation. 24,633,469 contracts compromised including 5.11M IBANs.	CNIL SAN-2026-001/SAN-2026-002; Security Affairs (2024); The Register (2026)
2025	FreeWifi_Secure IMSI vulnerability — separate flaw in Free's public WiFi network disclosed.	Security researchers (2025)
Jan 2026	CNIL issues SAN-2026-001 (Free Mobile, €27M) and SAN-2026-002 (Free, €15M). Largest CNIL sanction in French history. Injunctions: Free Mobile €50,000/day; Free €25,000/day.	CNIL deliberations SAN-2026-001 and SAN-2026-002, 8 January 2026

Figure 3. Timeline of Free / Iliad Group security incidents and regulatory sanctions

4. Zero Trust Architecture Framework

Zero Trust Architecture (ZTA), as officially described by the United States National Institute of Standards and Technology in Special Publication 800-207, is a paradigm shift away from the perimeter-based security model that has been the dominant paradigm of enterprise architecture over the last three decades. The perimeter model is based on an implicit trust model: entities that are authenticated at the network boundary are considered trusted on the internal network, and security measures are aimed at preventing external intrusion, but not internal access. ZTA dismisses this assumption. As Rose et al. (2020) state in NIST SP 800-207, zero trust assumes there is no implicit trust granted to assets or user accounts based solely on their physical or network location — whether on the local area network or connected via VPN — and that zero trust focuses on protecting resources, not network segments, as the network location is no longer seen as the prime component of the security posture. This theoretical re-alignment can be directly applied to the Free breach: the attacker was able to get into the VPN perimeter and was then treated as a trusted entity by all layers of the architecture — VPN gateway, MOBO application, subscriber database — until it decided to declare its presence.

4.1 The Seven Tenets

NIST SP 800-207 outlines seven tenets that, when combined, constitute a ZTA-compliant security design. The first tenet, which states that all data sources and computing services are resources to be secured, defines that all systems, applications, and data stores are resources that need to be explicitly governed in terms of access control irrespective of their location in the network. When applied to Free, this implies MOBO, the VPN gateway, the subscriber database, and all third-party data processor connections are resources that must be explicitly controlled, not presumed-safe internal components. The second tenet requires that any communication be secured irrespective of network location, and that the idea of a trusted internal network be eliminated: traffic between a VPN-connected endpoint and MOBO does not imply any implicit security guarantees and should be verified and monitored separately. The third tenet requires per-session access grants: individual enterprise resources are granted access on a per-request basis, and must be re-evaluated at each session.

The fourth tenet is the policy model: access is based on dynamic policy, including the identity of the requestor at the time, the health of the device, geolocation, access time, and behavioural context, rather than by fixed network perimeter policies or past access history. The fifth tenet demands constant monitoring and measurement of all owned and related assets, which forms the telemetry base without which anomaly detection cannot be achieved. The sixth tenet — most directly violated in the Free case — requires that all resource authentication and authorisation be dynamic and strictly enforced before access is allowed. The seventh tenet requires ongoing gathering of data on asset conditions, network infrastructure activity, and communications — the intelligence layer that drives the dynamic policy engine and the anomaly detection systems (Rose et al., 2020).

When the eight weaknesses of Free are plotted against these tenets, a pattern of ZTA non-compliance is evident and thorough. W1 is a direct violation of Tenet 6: authentication was not dynamic or strictly enforced, but based on a single credential check at the network perimeter. W2 breaches Tenets 3 and 4: MOBO access was not per-session or dynamically context-aware policy-based, but a persistent, undifferentiated grant. W3 contravenes Tenet 7: no meaningful telemetry gathering, no behavioural baseline, no anomaly detection — the enterprise was operationally blind to what was happening in its own IS. W4 breaches Tenet 1: the 15+ million retained terminated contracts are unmanaged resources that increased the surface of the breach. W6 breaches Tenet 2: the data flows of third parties were not systematically secured irrespective of network location. W7 and W8 are the organisational infrastructure failures that enabled all other ZTA violations to be sustainable.

4.2 The Three Logical Components

Besides the seven tenets, NIST SP 800-207 describes three logical components that operationalise ZTA in a real architecture: the Policy Engine (PE), which compares access requests with the policies established by the enterprise and grants or denies access; the Policy Administrator (PA), which implements the decisions made by the PE by configuring access pathways and communicating policy decisions to enforcement points; and the Policy Enforcement Point (PEP), which intercepts all resource requests and enforces the PA's decisions. In practice, the PE is an IAM platform that scores contextual risks; the PA is the orchestration layer of a ZTNA or PAM

solution; and the PEP is the ZTNA gateway or PAM proxy where all resource requests are redirected.

Free's pre-breach architecture did not have any of the three components in any significant form. The PE was absent — access decisions were made during VPN authentication and implicitly extended to all internal resources. There was no PA — no orchestration layer determined what MOBO access a given authenticated session would have. The PEP was absent, and MOBO was not behind an enforcement gate but was directly accessible to any VPN-authenticated session. The solutions suggested in Section 5 are structured around the implementation of each of these three components for the systems that were compromised in October 2024. Palo Alto Networks (2024) identifies three implementation pillars through which ZTA tenets are transformed into operational controls: centralised policy decision logic, per-session access grants, and continuous identity verification — and ZTA is not a single product deployment but an architectural posture that necessitates coordinated changes in authentication, access management, monitoring, and governance.

5. Proposed Improvements and Solutions

The eight solutions suggested in this section address the particular structural weaknesses identified in Section 3. All solutions are based on the principles of Zero Trust Architecture from NIST SP 800-207, with the relevant official standards and industry guidelines, and adjusted to the unique organisational environment of Free/Iliad. The key distinguishing argument throughout is organisational specificity: the solutions offered are not generic vendor advice but actions specific to the resources, subsidiaries, and infrastructure that the Iliad Group already has. The Reveelium platform of ITrust directly covers W2, W3, and W5. The ISO 27001-certified ISMS of Free Pro provides the basis for documentation and audit of W7. The DSPM tooling for W4 is hosted on Scaleway sovereign French cloud infrastructure with no risk of Cloud Act exposure. All eight solutions can be implemented with current group capabilities — no new procurement budgets are needed, only governance decisions. A consolidated overview is given in Table 3 below.

#	Solution	Specific to Free/Iliad	ZTA Tenet	Standard Reference	Compliance Addressed
W1	ZTNA + FIDO2 MFA + Machine Certificate	Replace legacy VPN; enforce FIDO2 hardware tokens; integrate machine certificate validation in ZTNA client for all remote endpoints accessing Free Mobile IS	Tenet 6 — Dynamic auth before every session	NIST SP 800-207; ANSSI-PG-078	GDPR Art. 32; NIS2 Art. 21(2)(j)
W2	PAM + Zero Standing Privilege + JIT Access	Deploy PAM for MOBO; time-limited JIT grants scoped to task; audit all privileged sessions; feed to Reveelium UEBA for behavioural baselining	Tenets 3 & 4 — Per-session least-privilege; dynamic policy	NIST SP 800-207; NIST SP 800-53 AC-2	GDPR Art. 32; NIS2 Art. 21(2)(i)
W3	24/7 SOC + Reveelium SIEM/UEBA/SOAR	Extend ITrust Reveelium scope to Free Mobile VPN, MOBO, subscriber DB; connect to ITrust 24/7 SOC; UEBA behavioural baselines for all admin users	Tenet 7 — Continuous telemetry and analysis	NIST SP 800-207; NIST SP 800-61 Rev.3	GDPR Art. 32; NIS2 Art. 21(2)(b)
W4	DSPM + Automated	Deploy DSPM on	Tenet 1 — All	NIST SP 800-207;	GDPR Art. 5(1)(e),

	Data Purge	Scaleway sovereign cloud; classify subscriber data by retention category; automate GDPR Art. 5(1)(e) purge; generate Art. 30 RoPA automatically	data resources managed and protected	Gartner DSPM 2022	Art. 30; NIS2 Art. 21(2)(a)
W5	Formalised IRP + SOAR Notification Automation	Draft GDPR Art. 34(2)-compliant templates with DPO sign-off; SOAR playbooks for breach triage, CNIL 24h notification, and subscriber communication dispatch	Tenet 7 — Incident detection and structured response	NIST SP 800-61 Rev. 3; NIS2 Art. 23	GDPR Art. 33 & 34; NIS2 Art. 23
W6	TPRM + DLP + NIS2 Supply Chain Clauses	Inventory all third parties with subscriber data access; mandatory ISO 27001 for critical suppliers; embed NIS2 Art. 21(2)(d) clauses and right-to-audit; DLP at all transfer boundaries	Tenet 2 — All communications secured	NISTIR 8276; NIS2 Art. 21(2)(d)	GDPR Art. 32; NIS2 Art. 21(2)(d)
W7	ISO 27001 Extension to Free and Free Mobile	Extend group ISMS scope from Free Pro/OpCore to consumer entities; leverage existing ISMS as template; gap assessment + Stage 1 + Stage 2 audit within 18 months	Tenet 5 — Monitor integrity of all assets	ISO/IEC 27001:2022; NIS2 Art. 21(1)	GDPR Art. 32(3); NIS2 Art. 21(1)
W8	Group CISO + COMEX Cyber Committee	Appoint Group CISO reporting to CEO; quarterly COMEX cyber committee; cyber KPIs in annual reporting; mandatory NIS2 Art. 20(2) board training	Tenet 4 — Enterprise-wide dynamic policy	NIS2 Art. 20; ISO 27001 Cl. 5	NIS2 Art. 20; GDPR Art. 32

Table 3. Proposed ZTA-aligned solutions for Free / Iliad Group information security design weaknesses. Sources: NIST SP 800-207 (Rose et al., 2020), NISTIR 8276 (NIST, 2021), NIST SP 800-61 Rev. 3 (NIST, 2025), ISO/IEC 27001:2022 (ISO, 2022), NIS 2 Directive (European Parliament, 2022).

5.1 Solution for W1 — Zero Trust Network Access and FIDO2 Phishing-Resistant MFA

The most architecturally immediate answer to the VPN authentication failure is to replace the existing corporate VPN with a Zero Trust Network Access (ZTNA) solution with FIDO2 phishing-resistant MFA and implementation of the machine. The difference between VPN and ZTNA is conceptual: according to Cisco Duo (2024), a VPN puts users into the corporate network where they can access more than they likely need, a configuration that increases the attack surface. ZTNA authenticates each user, device, and access request in real-time and only allows access to particular applications and not to the entire internal network. This architectural difference implies that even a successful credential theft, in a ZTNA-secured environment, would only provide access to the specific resource the attacker has been authorised to access, but not the entire internal IS.

FIDO2 credentials are founded on an entirely different trust model than OTP codes or password-plus-SMS MFA. FIDO2 credentials are cryptographically tied to the registered device and the particular service: unlike one-time PINs, FIDO2 MFA cannot be intercepted by an attacker (as Cloudflare (2024) documents). This phishing resistance directly addresses the initial access vector in the Free breach. If the attacker had gotten credentials through phishing or credential stuffing, FIDO2 would have made them useless without the physical hardware token that belonged to the real user. The machine certificate deployed through the ZTNA client offers a device-level authentication tier: only managed, corporate-enrolled endpoints with registered certificates in the ZTNA policy engine are allowed to initiate a session.

Sector benchmarks support the business case for migration. Organisations transitioning from VPN to ZTNA typically see an 80% reduction in remote access support tickets and a 30–50% reduction in remote access infrastructure costs over three years (Cloudflare, 2024). By 2024, 78% of organisations planned to implement Zero Trust strategies within twelve months (Cisco Duo, 2024) — indicating that ZTNA is not a new technology but a well-established and widely used solution. Article 21(2)(j) of NIS 2 requires Essential Entities to apply MFA or continuous authentication where appropriate; for an operator with 23 million subscriber contracts managed through remotely accessible tools, the appropriateness is evident (European Parliament, 2022).

5.2 Solution for W2 — Privileged Access Management with Just-In-Time Provisioning

Privileged Access Management with Just-in-Time access provisioning and Zero Standing Privilege fills the MOBO access gap at its structural basis by eliminating the undifferentiated access that perpetuated the attack. In a PAM-controlled model, operators that need access to MOBO are provided with time-limited sessions scoped to the task at hand: a customer service agent who needs to access a billing dispute record is provided with a 30-minute session with access to that subscriber's record category, but not the whole database. When the time limit is up, access is automatically revoked. Zero Standing Privilege means that no user account is permanently given high privileges to MOBO — access must be requested, granted on a dynamic policy, and time-limited.

Palo Alto Networks (2024) notes that the elimination of standing privileges and just-in-time access would severely restrict the movement of attackers once a credential compromise has occurred — exactly the control that would have restricted the Free breach to the specific records to which the compromised session was authorised. With JIT provisioning in place, the 24.6 million records stolen over 16 days of active querying would have been architecturally infeasible: no single access grant would have provided the persistent, unlimited querying ability that the attacker used.

The Reveelium integration would benefit the deployment path: all PAM privileged sessions involving MOBO would be logged and their behavioural telemetry sent to the ITrust Reveelium UEBA engine as a high-risk user behaviour stream. This forms a self-reinforcing control architecture: PAM restricts the scope and duration of access, and UEBA monitors real-time session behaviour and triggers SOAR containment in case of anomalies. The whole stack — PAM orchestration, UEBA baselining, SOAR response — is already available in the ITrust Reveelium platform that Iliad Group has deployed to B2B clients.

5.3 Solution for W3 — 24/7 SOC with Reveelium SIEM, UEBA, and SOAR

The W3 solution is already in operation in the Iliad Group. The Reveelium platform of ITrust, which is based in the SOC and processed more than one million alerts and 400,000 identified threats on behalf of external customers in the twelve months before June 2024, offers all four

capabilities needed: SIEM event correlation, UEBA behavioural profiling, SOAR-automated incident response playbooks, and 24/7 SOC analyst coverage (ITrust, 2025). It is not procurement but scope extension: to feed Reveelium with monitoring data of the Free Mobile VPN gateway, MOBO application, and subscriber database on top of its existing external client feeds.

Technical justification of UEBA as the main detection mechanism is well-founded. Microsoft (2024) states that UEBA detects anomalies by comparing current activity with set baselines and scoring deviations in data access volumes, geographical locations, and frequency patterns of activities. CrowdStrike (2024) confirms that SIEM is efficient at detecting known threats based on existing rules, whereas UEBA detects subtle and advanced threats that are not yet known. The Free breach was not stealthy or sophisticated: it would have been flagged by any operational UEBA system in the first session of anomalous MOBO querying.

The Reveelium V12.3 release adds LLM-based SOAR integration, automating incident response playbooks and reducing SOC analyst workload and mean time to contain (ITrust, 2025). In the case of the Free breach, a Reveelium SOAR playbook triggered by a UEBA volumetric anomaly on MOBO would automatically isolate the suspicious VPN session, revoke the corresponding credential, alert the SOC analyst with full session telemetry, and start the GDPR Art. 33 72-hour notification clock — all within minutes. The Reveelium platform is compatible with NIS 2 and provides automated incident reporting that complies with Art. 23 preliminary notification requirements (ITrust, 2025). The CESIN 11th Barometer confirms that SOC deployment, 94% MFA deployment, and 95% EDR deployment are now almost universal among large French enterprises (CESIN, 2026) — the absence of these measures at Free before the breach was a measurable outlier.

5.4 Solution for W4 — Data Security Posture Management and Automated Retention Enforcement

DSPM is a term coined by Gartner in 2022 and included in its 2024 Hype Cycle for Data Security, which offers an understanding of where sensitive data is stored, who can access it, how it has been used, and the security posture of the data store or application (Gartner, cited in Securiti, 2024). The Art. 5(1)(e) finding of the CNIL is directly addressed by the core capabilities of DSPM: automated discovery scans all environments to determine where personal data is stored; classification sorts

records by legal retention category — active subscriber, terminated within period, terminated beyond period, IBAN record; and automated enforcement triggers purge workflows on non-compliant records. A DSPM solution that scanned the Free Mobile subscriber database would have automatically identified the 15+ million terminated contracts as non-compliant and initiated controlled, staged purge operations — without the manual intervention that Free alleged was operationally impractical.

Article 30 GDPR Records of Processing Activities is also covered by DSPM, which automates what would otherwise be 40–80 hours of manual DPO work per review cycle into a constantly updated, automatically generated output (Securiti, 2024). Article 21(2)(a) of NIS 2 also mandates information system security policies that cover data lifecycle — DSPM offers the technical implementation. This is a category of production-ready solution, not an experimental technology, with Gartner estimating that over 20% of organisations will prioritise DSPM technologies by 2026.

The deployment environment is Scaleway, the sovereign French public cloud of the Iliad Group. The DSPM tooling scanning the Free subscriber database, which holds 5+ million IBAN records, must run in an environment not subject to US Cloud Act data access requests. Scaleway is explicitly Cloud Act-free sovereign infrastructure, making it the logical place to deploy — it also addresses the retention compliance gap of W4 and the data sovereignty posture that France's regulatory framework requires of Essential Entities.

5.5 Solution for W5 — Formalised Incident Response Plan with SOAR-Automated Notification

NIST SP 800-61 Rev. 3 requires organisations to design, develop, and continue to operate a formal incident response capability (NIST, 2025). The four-phase Incident Response Lifecycle framework — Preparation, Detection and Analysis, Containment/Eradication/Recovery, and Post-Incident Activity — provides the framework within which the GDPR Art. 33 (72-hour notification to the supervisory authority) and Art. 34 (notification of subscribers without undue delay) requirements will be operationalised. Free not notifying was not a mistake under pressure of communications: it was the logical outcome of a process that did not have a pre-approved template, DPO review process, legal sign-off process, or content checklist as per the requirements of Art. 34(2) GDPR.

An IRP based on SOAR would have made the notification procedure an automated execution of protocols as opposed to a crisis communications exercise. An Art. 34(2)-compliant notification would be generated by a notifiable breach SOC alert and delivered to affected subscribers within a given timeframe, using pre-approved templates, filled with breach-specific information, and routed through DPO and legal review queues. The Art. 33 GDPR supervisory notification to the CNIL and the NIS 2 Art. 23 preliminary notification are both handled using the same playbook within 72 hours and 24 hours respectively. NIST SP 800-61 Rev. 3 incorporates incident response into the NIST CSF 2.0 Respond and Recover functions, providing a systematic approach to continuous improvement through post-incident lessons-learned reviews and plan updates (NIST, 2025) — which also fits into the ISO 27001 PDCA cycle once the W7 certification extension is obtained.

5.6 Solution for W6 — Third-Party Risk Management with NIS2-Aligned Supply Chain Security

NISTIR 8276 assumes that organisations can no longer defend themselves solely by securing their own infrastructure, as threat actors specifically target the suppliers of more cyber-mature organisations to exploit the weakest link (NIST, 2021). The proposed TPRM programme of Free is founded on the Key Practices of NISTIR 8276: the full list of all suppliers that have access to subscriber data, prioritised by the sensitivity of data and the criticality of a system; formal evaluation of supplier cybersecurity posture; and the right-to-audit as the non-negotiable conditions of any data processing contract. Art. 21(2)(d) of NIS 2 provides the legal framework, requiring Essential Entities to address security in their relationships with direct suppliers and service providers (European Parliament, 2022).

Data Loss Prevention is the technical enforcement layer at all third-party data transfer boundaries. DLP solutions analyse outbound traffic to detect patterns matching defined categories of sensitive data — subscriber IBAN records, customer PII, account credentials — and block or flag transfers that violate defined policies. Together with the DSPM solution suggested for W4, which offers real-time information about the location of sensitive data assets within the IS, DLP at third-party transfer points establishes a closed loop: DSPM detects sensitive data assets, DLP applies policy at the point where the data leaves the controlled environment. The CESIN 11th Barometer confirms that 43% of attacks on large French enterprises follow third-party vectors (CESIN, 2026). TPRM is

not merely a means to meet the requirements; it is the most effective security control for an operator of the size of Free.

5.7 Solution for W7 — ISO 27001 Certification Extended to Free and Free Mobile

The extension of the ISO 27001 certification scope to the consumer subsidiaries Free SAS and Free Mobile SAS is the most structurally significant governance action, and the most realistic to take based on the current group resources. The 93 controls of ISO 27001:2022 are directly related to the eight weaknesses identified in this analysis: access control (W1, W2), incident management (W3, W5), information classification (W4), supplier relationships (W6), and leadership accountability (W7, W8). The consumer subsidiaries do not undergo the systematic risk assessments, third-party audits, and management accountability mechanisms without certification, which would bring to light and require remediation of these gaps. According to ISO (2022), NIS 2 guidance specifically proposes ISO 27001 as a tool that Essential Entities can use to demonstrate Article 21 compliance, and thus certification is at the same time a security governance tool and a regulatory risk management tool.

The available group infrastructure is beneficial to the implementation path. The documentation template for the scope extension will be the ISO 27001 ISMS of Free Pro, which covers 12 datacenters with risk assessment procedures, access control standards, supplier assessment procedures, and audit frameworks. Both the Stage 1 documentation review and Stage 2 on-site audit required for certification can be performed with in-house competence: Free has technical teams already operating within the certified infrastructure of the group, and ITrust has ANSSI-qualified cybersecurity expertise internally. Data breaches in certified organisations are estimated to cost 30% less (ISO, 2022); the certification investment has a highly positive payoff compared to the €42 million in CNIL sanctions already paid.

5.8 Solution for W8 — Group CISO, COMEX Cyber Committee, and Governance Programme

The governance deficit outlined in W8 is the enabling precondition of all other weaknesses. In the absence of board-level accountability, executive ownership of cybersecurity risk, and a designated Group CISO with the authority to allocate budgets and oversee technical solutions W1 through W7, technical solutions will not be consistently prioritised, funded, implemented, or monitored. NIS 2 Article 20 directly addresses this: management bodies must formally endorse cybersecurity risk management practices and oversee their implementation; Article 20(2) requires that members of management bodies receive regular cybersecurity training to enable them to identify risks and assess security practices (European Parliament, 2022). Non-compliant executive liability is explicitly defined — a provision specifically designed to prevent the delegation of governance that leaves technical teams operating without board-level accountability.

The three elements of the proposed governance programme are mutually reinforcing. First, the appointment of a Group CISO with COMEX-level visibility, the authority to enforce security standards across all subsidiaries including consumer entities, and a dedicated security investment budget — responsible for the overall ZTA transition programme, the ISO 27001 scope extension, and the deployment of ITrust Reveelium across the Free Mobile IS. Second, the establishment of a quarterly COMEX-level cyber risk committee comprising the Group CISO, DPO, CFO, legal counsel, and operational IT leadership — creating the cross-functional governance structure that NIS 2 Art. 20 requires. Third, the inclusion of cybersecurity KPIs — SOC alert response times, vulnerability remediation times, third-party compliance rates, and regulatory audit outcomes — in the annual reporting of Iliad Group, making cyber governance a public accountability measure.

The mandatory training of management body members under NIS 2 Article 20(2) provides the framework for developing board-level cyber risk literacy: a formal annual training programme on threat landscape awareness, regulatory compliance, breach scenario drills, and ZTA principles for all COMEX and board members. The CESIN 11th Barometer confirms that 90% of French enterprises have COMEX-level cyber governance (CESIN, 2026), which shows that this structure is the norm. The ITrust acquisition by Iliad Group shows that the group is capable of making strategic cybersecurity investments; the governance programme ensures that these investments are directed both inwards and outwards.

ZTA Component	Current State (Before)	Target State (After Proposed Solutions)
Authentication	Single-factor VPN; no machine certificate; no device-level verification	FIDO2 phishing-resistant MFA + machine certificate via ZTNA client; per-session dynamic re-evaluation
Network Access	Legacy VPN grants broad internal network access; no microsegmentation	ZTNA: per-application access grants; microsegmented access to MOBO only; no implicit trust post-authentication
Privileged Access	No PAM; persistent admin access to MOBO; no JIT; no session recording	PAM + Zero Standing Privilege + JIT; all MOBO sessions recorded and fed to Reveelium UEBA
Monitoring	No SOC; anomaly detection ineffective; 25-day breach undetected	ITrust Reveelium SOC 24/7; SIEM + UEBA baselines on MOBO users; SOAR automated containment
Data Protection	15M+ terminated contracts retained; non-robust MOBO password hashing; no DSPM	DSPM on Scaleway; automated GDPR Art. 5(1)(e) purge; memory-hard hashing (Argon2); DLP at transfer points
Incident Response	No IRP; breach discovered by attacker; Art. 34 GDPR notification non-compliant	NIST SP 800-61 Rev. 3 IRP + SOAR; GDPR Art. 34(2)-compliant notification templates; NIS2 Art. 23 playbooks
Supply Chain	No TPRM; no security requirements for data processors; no DLP at transfer points	NISTIR 8276 TPRM; ISO 27001 mandatory for critical suppliers; NIS2 Art. 21(2)(d) clauses + annual assessments
Governance	No Group CISO; no COMEX cyber committee; no ISO 27001 consumer entities; SOC post-breach only	Group CISO + COMEX quarterly committee; ISO 27001 extension within 18 months; cyber KPIs in annual report

Figure 4. Proposed Zero Trust Architecture transition for Free / Iliad Group: current state versus target state.

6. Recovery Strategies and Compliance Management

Security design is not merely incident prevention but the systematic response to it - and compliance control as an operational practice in the long term. In Free/Iliad, there are time-constrained requirements in the regulatory environment on both fronts. This section addresses business continuity and disaster recovery planning, incident response recovery procedures and the framework of continuing compliance management, which operationalise the technical solutions suggested in Section 5.

6.1 Business Continuity and Disaster Recovery Planning

The organisational resilience standard is NIST SP 800-34 Rev. 1, which has a well-defined taxonomy of continuity plans. The Business Continuity Plan (BCP) covers the continuity of business operations in an organization in case of a disruption (NIST, 2010); in the case of Free, it would mean the continuity of subscriber services, billing and customer support in the event of a security breach. The Disaster Recovery Plan (DRP) covers the recovery of IT infrastructure and operations after a disastrous event - in the case of Free, this would be the recovery steps for MOBO, the VPN gateway and the subscriber database. The Cyber Incident Response Plan (CIRP) is linked to NIST SP 800-61 Rev. 3 and bridges the technical response with the legal notification requirements.

The implementation plan is grounded in the seven-step contingency planning process of NIST SP 800-34. The Business Impact Analysis (BIA) step is especially important for Free: it identifies, system-by-system, the Recovery Time Objective (RTO) and Recovery Point Objective (RPO) that define the tolerable limits of disruption for each mission-critical system. The operationally defined targets for Free's critical systems would be: MOBO - RTO 4 hours, RPO 2 hours; VPN gateway - RTO 1 hour, RPO 0; subscriber database - RTO 8 hours, RPO 1 hour; billing systems - RTO 4 hours, RPO 1 hour. These targets drive the technical requirements for backup architecture, failover setup and recovery testing. NIST SP 800-34 defines resilience as an end-state, not a process - the aim is to ensure that mission-essential functions remain available at all times regardless of any disruption (NIST, 2010).

Article 21(2)(c) of NIS 2 explicitly requires that Essential Entities have business continuity, backup management, disaster recovery, and crisis management in place (European Parliament, 2022). The absence of a formalised BCP/DRP at Free is both a security design failure and a regulatory non-compliance. Aligning NIS 2 Art. 21(2)(c), NIST SP 800-34, ISO 27001 Annex A business continuity controls, and the NIST CSF Recover function creates a standards-based continuity architecture. Tabletop exercises simulating the October 2024 attack chain - VPN credential compromise, MOBO access, mass exfiltration, CNIL notification timeline - would test recovery procedures and surface gaps before they become a regulatory reality.

6.2 Continuous Compliance Management

Both the October 2024 breach and the subsequent €42 million CNIL fine are indicators of a compliance governance failure, rather than a technical one. Free had some compliance credentials but failed to apply them as effective security controls over its consumer business. The ISO 27001 Plan-Do-Check-Act cycle, which involves a regular review of the effectiveness of controls in a dynamic threat environment, was not effectively applied at Free or Free Mobile. Had it been, the authentication failures that CNIL reported as non-compliant with standards published in 2017, 2018 and 2021 would have been identified during an internal audit, rather than a formal investigation following a record sanction.

The proposed continuous compliance management programme of Free is based on four functional components. First, a compliance monitoring dashboard that consolidates DSPM output (data retention compliance, RoPA completeness), Reveelium SOC telemetry (access anomaly metrics, IRP SLA performance), PAM audit logs (JIT policy adherence), and TPRM system outputs (supplier compliance rates) into a real-time visibility layer for the Group CISO and DPO. This transforms compliance from a one-time attestation into a state of continuous operational monitoring. Second, a quarterly compliance review in the form of an ISO 27001 Clause 9.3 management review, covering the current threat environment, the adequacy of controls against evolving ANSSI and CNIL guidance, supplier assessment findings, and new regulatory requirements. Third, an external security assessment programme comprising an independent penetration test of the ZTNA gateway, MOBO access controls, and PAM implementation; a red

team exercise simulating the October 2024 attack chain against the hardened architecture; and an ISO 27001 surveillance audit once the scope extension is complete.

Fourth, a supplier compliance calendar under which all third parties with access to subscriber data are assessed against NIS 2 Art. 21(2)(d) requirements annually, semi-annually for Tier 1 critical suppliers, and with formal remediation tracks for suppliers failing to meet specified compliance standards. The legal rationale behind this model is reflected in the Altij Avocats (2026) analysis of the CNIL proceedings: the CNIL does not sanction the breach itself, but the failure to implement measures commensurate with the risk and in line with the state of the art. That state of the art moves with the threat - an organisation with sound controls in 2025 that fails to update them against a 2027 threat environment is exposed. Continuous compliance management is therefore the governance-level implementation of ZTA Tenet 7: continuous collection and analysis of information on the security posture of all assets.

7. Conclusion

This report has examined the information security design of Free and Iliad Group through the critical lens of official regulatory evidence, industry threat intelligence and the Zero Trust Architecture framework. Eight structural weaknesses have been identified and documented based on primary source evidence and mapped against the seven tenets of NIST SP 800-207. Each weakness has been matched to a specific, organisationally calibrated solution and justified by reference to the relevant standards, sector benchmarks, and resources within the Iliad ecosystem.

The main finding is clear: the October 2024 breach was not the result of a sophisticated attack, an unforeseen threat actor, or a lack of resources. Its structural security design failures had already been documented, officially warned against, and in two instances sanctioned by the CNIL in 2021 and 2022 - the 2024 breach was the predictable outcome. The CNIL finding that a sequence of common security failures allowed the attacker to move step by step through the IS (Village Justice, 2026) is analytically accurate: each failure maps to a recognisable ZTA gap, and each gap has a known, available technical remedy. There was no meaningful architectural resistance anywhere in the attack chain.

The most analytically significant aspect of the case is the ITrust paradox. In April 2023, Iliad Group released Reveelium - a commercial cybersecurity product specifically designed to detect the exact attack pattern that compromised Free Mobile eighteen months later: volumetric data access via a privileged management tool, executed over an extended period using compromised credentials. ITrust was using Reveelium to protect six CAC 40 companies and various French government ministries. It was not deployed to protect the 23 million subscribers of its parent company's own consumer telecommunications subsidiary. This is not a technical failure. It is a governance failure - an implicit or explicit strategic decision to treat cybersecurity as a commercial product rather than an internal operational necessity.

The implications extend beyond Free. In 2023, ANSSI assessed the threat to the French telecommunications sector as critical and documented a structural prioritisation of availability over security (ANSSI / CERT-FR, 2023). The 2024 intrusions at SFR, Bouygues Telecom, and Free - all via similar internal subscriber management tools - confirm that this is an industry-wide design debt. With NIS 2 Essential Entity requirements now fully enforced and the CNIL demonstrating

readiness to impose group-turnover-based, record-scale sanctions, the sector faces a structural shift: the availability-first, perimeter-based model is no longer commercially or legally viable. Zero Trust Architecture, implemented with the organisational specificity and governance accountability described in this report, is the path to that transition. For Iliad Group, the necessary infrastructure is already in place. The remaining question is whether it will be governed inward before the next incident compels it.

References

Altij Avocats. (2026). *FREE et FREE MOBILE lourdement sanctionnés par la CNIL.* https://www.altij.fr/detail-actualites/detail-actualites-donnees-bases-de-donnees/free-et-free-mobile-lourdement-sanctionnes-par-la-cnil

Agence Nationale de la Sécurité des Systèmes d'Information (ANSSI) / CERT-FR. (2021). *Recommandations relatives à l'authentification multifacteur et aux mots de passe* (ANSSI-PG-078). https://cyber.gouv.fr/publications/recommandations-relatives-lauthentification-multifacteur-et-aux-mots-de-passe

Agence Nationale de la Sécurité des Systèmes d'Information (ANSSI) / CERT-FR. (2023). *État de la menace ciblant le secteur des télécommunications* (CERTFR-2023-CTI-010). https://www.cert.ssi.gouv.fr/cti/CERTFR-2023-CTI-010/

Agence Nationale de la Sécurité des Systèmes d'Information (ANSSI) / CERT-FR. (2025). *Panorama de la cybermenace 2024* (CERTFR-2025-CTI-003). https://www.cert.ssi.gouv.fr/cti/CERTFR-2025-CTI-003/

CESIN / OpinionWay. (2026). *Baromètre de la cybersécurité des entreprises — 11ème édition (vague 2025).* https://cesin.fr

Cisco Duo. (2024). *ZTNA vs VPN: Which one is better for your business?* https://duo.com/learn/ztna-vs-vpn

Cloudflare. (2024). *Phishing-resistant MFA with FIDO2.* https://www.cloudflare.com/sase/use-cases/phishing-resistant-mfa/

Commission Nationale de l'Informatique et des Libertés (CNIL). (2021). *Délibération SAN-2021-021 — Sanction Free Mobile (€300,000).* https://www.cnil.fr

Commission Nationale de l'Informatique et des Libertés (CNIL). (2022). *Délibération SAN-2022-021 — Sanction Free (€300,000).* https://www.cnil.fr

Commission Nationale de l'Informatique et des Libertés (CNIL). (2026). *Violation de données : sanction de 42 millions d'euros à l'encontre des sociétés FREE MOBILE et FREE* (SAN-2026-001 and SAN-2026-002, 8 January 2026). https://www.cnil.fr/fr/sanction-free-2026

CrowdStrike. (2024). *UEBA vs SIEM: Solution roles and differences.* https://www.crowdstrike.com/en-us/cybersecurity-101/next-gen-siem/ueba-vs-siem/

European Parliament and Council of the European Union. (2016). *Regulation (EU) 2016/679 — General Data Protection Regulation (GDPR).* https://eur-lex.europa.eu/eli/reg/2016/679/oj

European Parliament and Council of the European Union. (2022). *Directive (EU) 2022/2555 — NIS 2 Directive.* https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng

European Union Agency for Cybersecurity (ENISA). (2024). *ENISA Threat Landscape 2024.* https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024

Free Pro. (2024). *XPR — Infrastructure et certifications.* https://xpr.freepro.com/

Freenews. (2026). *Cyberattaques : Free muscle sa sécurité après la fuite massive de 2024.* https://www.freenews.fr/securite/free-renforce-securite-apres-cyberattaque

Glocert International. (2024). *NIS2 governance and management accountability.* https://www.glocertinternational.com/resources/guides/nis2-governance-and-management-accountability/

Haas Avocats. (2026). *Violation de données chez Free : sanction record de la CNIL.* https://www.haas-avocats.com/contentieux/sanctions/violation-de-donnees-chez-free-sanction-record-de-la-cnil/

Iliad Group. (2023). *Le Groupe iliad prend une participation majoritaire au capital d'ITrust* [Press release]. GlobeNewswire. https://www.globenewswire.com/news-release/2023/04/04/2640267/0/fr/

Iliad S.A. (2025). *Le Groupe iliad enregistre une année record et change de dimension* [Press release]. GlobeNewswire. https://www.globenewswire.com/fr/news-release/2025/03/25/3048430/

International Organization for Standardization / International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022 — Information security management systems.* https://www.iso.org/standard/27001

ITrust SAS. (2025). *ITrust — Pôle d'expertise en cybersécurité IA du Groupe iliad / Reveelium V12.3.* https://www.itrust.fr/

Microsoft Security. (2024). *What is user and entity behavior analytics (UEBA)?* https://www.microsoft.com/en-us/security/business/security-101/what-is-user-entity-behavior-analytics-ueba

National Institute of Standards and Technology. (2010). *Contingency planning guide for federal information systems* (NIST SP 800-34 Rev. 1). https://doi.org/10.6028/NIST.SP.800-34r1

National Institute of Standards and Technology. (2021). *Key practices in cyber supply chain risk management* (NISTIR 8276). https://doi.org/10.6028/NIST.IR.8276

National Institute of Standards and Technology. (2025). *Computer security incident handling guide* (NIST SP 800-61 Rev. 3). https://doi.org/10.6028/NIST.SP.800-61r3

Palo Alto Networks. (2024). *What is NIST SP 800-207? Zero Trust Architecture framework.* https://www.paloaltonetworks.com/cyberpedia/what-is-nist-sp-800-207

Rineau, B., & Hamou Maamar, S. (2026). Violation de données : la CNIL sanctionne Free Mobile et Free. *Village Justice.* https://www.village-justice.com/articles/violation-donnees-cnil-sanctionne-free-mobile-free,56222.html

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST SP 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Securiti. (2024). *What is DSPM?* https://securiti.ai/what-is-dspm/

Security Affairs. (2024). *France's second-largest telecoms provider Free suffered a cyber attack.* https://securityaffairs.com/170333/data-breach/free-suffered-a-cyber-attack.html

Usine Digitale / IT-Connect. (2024). *SFR cyberattacks 2024.* https://www.usine-digitale.fr

Verizon. (2024). *2024 Data breach investigations report* (17th ed.). https://www.verizon.com/business/resources/reports/dbir/